

Recommander des mesures d'atténuation des menaces

Objectifs

Partie 1: Analyser un incident dans une entreprise de production vidéo

Partie 2: Analyser un incident dans une entreprise de vente au détail

Contexte/scénario

La connaissance des vulnérabilités et des attaques du réseau n'est qu'une partie de la lutte. La réduction des menaces est l'objectif final du personnel de sécurité du réseau.

Dans cet atelier, vous allez lire deux études de cas qui décrivent des incidents liés à la sécurité du réseau. Il vous incombe de recommander des mesures d'atténuation des menaces pour faire face à chaque incident.

Ressources requises

= Accès à Internet

Instructions

Partie 1: Analyser un incident dans une entreprise de production vidéo

All Time Video Inc. est une entreprise qui produit des vidéos pour plusieurs clients. Ils utilisent des méthodes de production vidéo numériques et stockent leur contenu sur des serveurs de gestion de contenu spécialisés. Ils sont très fiers de leurs bibliothèques de contenu qui incluent un large éventail de séquences d'archives pouvant être utilisées dans des vidéos sur de nombreux sujets.

La direction de l'entreprise a reçu un e-mail d'un groupe de hackers. Dans l'e-mail, les hackers affirment avoir été en mesure de voler plusieurs téraoctets de ressources vidéo et de projets sur les serveurs de gestion de contenu. Les hackers menacent de télécharger les ressources vidéo sur divers serveurs sur Internet, à moins que l'entreprise ne paie une somme d'argent. La direction d'All Time Video craint de perdre un avantage concurrentiel si ses ressources sont rendues publiques.

L'entreprise a fait appel à une équipe de sécurité externe pour enquêter sur l'incident. L'enquête a révélé qu'un lot de clés USB disponibles lors d'un récent salon de la vidéo était infecté par des malwares. Le malware a infecté plusieurs hôtes sur le réseau All Time Video et s'est également propagé sur le réseau à d'autres machines. Le malware a analysé le réseau à la recherche de plusieurs types de logiciels de gestion de contenu et a déterminé la version du logiciel. Le malware a ensuite exploité les vulnérabilités d'une ancienne version non corrigée du logiciel pour y accéder. Une fois l'accès obtenu, le malware a informé les hackers qui ont ensuite pu installer un logiciel utilisant la tunnellation DNS pour voler progressivement les données des serveurs. Cela a été utilisé pour échapper à la détection. Pendant plusieurs mois, les hackers stockent des téraoctets de ressources vidéo.

Étape 1: Analyser l'attaque.

En tant que membre de l'équipe de sécurité "**All Time Video**", vous devrez nous faire part de vos idées sur la manière de limiter une telle attaque. Commencez par identifier les conditions qui ont conduit à l'attaque.

Que devait-il se passer pour que cette attaque se produise ?

Pour que cette attaque arrive, il y a eu plusieurs problème :

- Les employés ont utilisé des clés USB infecté récupéré à un salon sans les vérifier
- Le logiciel de gestion de contenu était une vieille version qui avait pas été mise à jour (non corrigée)
- Le réseau était pas assez sécurisé car le malware a pu scanner et se propager sur d'autre machines
- Le pare-feu n'a pas bloqué la tunnellation DNS, ce qui a permis de sortir les donnée

Étape 2: Recommander des techniques d'atténuation.

Pour chaque événement qui s'est produit au cours de cet incident, utilisez votre accès Internet pour étudier les techniques d'atténuation possibles. Vous êtes libre d'utiliser toutes les sources d'informations que vous pouvez trouver afin de recommander des techniques de réduction des menaces exploitables.

Voici ce qu'il faudrait faire pour éviter ça :

- Gestion des supports externes : Il faut interdire les clé USB inconnu ou forcer un scan antivirus automatique dès qu'on les branche.
- Mise à jour (Patching) : Il faut absolument garder les logiciel à jour pour corriger les failles de sécurité
- Segmentation du réseau : Il faudrait séparer les serveurs important du reste du réseau pour que le malware se propage pas partout.
- Surveillance DNS : Configurer le pare-feu pour inspecter le trafic DNS et bloquer les tunnel bizarre pour empêcher le vol de donnée

Partie 2: Analyser un incident dans une entreprise de vente au détail

Une entreprise de vente au détail de taille moyenne est spécialisée dans la vente de pièces détachées personnalisées. Un client a appelé l'entreprise pour informer l'entreprise que ses données personnelles et les informations relatives à sa carte bancaire se trouvaient sur Internet. Une enquête a montré que des hackers ont pu infiltrer le réseau de l'entreprise via la connexion réseau d'un fournisseur d'équipement. Le but de la connexion est de surveiller un outil de travail du bois contrôlé par ordinateur qui est utilisé pour créer des cous et des corps de guitare. Le faible niveau de sécurité chez le fournisseur a permis aux hackers d'exploiter cette connexion. Les hackers ont pu localiser et accéder au serveur utilisé pour accepter les paiements des produits sur Internet. Les acteurs de la friandise ont exploité un compte d'utilisateur et un mot de passe faible pour accéder à la base de données des clients. Toutes les informations sur le client étaient présentées dans un fichier facile à lire. Le fichier a été chargé sur un serveur utilisé par des hackers et les informations ont été vendues à d'autres hackers.

Étape 1: Analysez l'attaque

Lisez la description de l'incident et répertoriez les étapes de l'attaque.

- Les hackers sont rentré par la connexion réseau du fournisseur d'équipement qui était mal sécurisé
- Ils ont localisé le serveur de paiement sur le réseau
- ils ont trouvé un compte utilisateur avec un mot de passe faible pour rentrer dans la base de données
- Ils ont copié le fichier client qui était en clair (facile à lire)
- Ils ont envoyé le fichier sur leur serveur pour le vendre

Étape 2: Recommander des mesures d'atténuation

Pour chaque événement qui s'est produit au cours de cet incident, recommander des mesures qui pourraient atténuer l'événement.

- Sécuriser les tiers : Il faut exiger que les fournisseur aient une sécurité forte (VPN, double authentification) pour se connecter.
- Isoler les machines : L'outil de travail du bois ne devrait pas être sur le même réseau que le serveur de paiement
- Politique de mot de passe : Il faut obliger les gens à mettre des mot de passe complexe et les changer souvent pour éviter le bruteforce

- Chiffrement : Les données des clients ne doivent jamais être stocké dans un fichier "facile à lire", il faut tout chiffrer

Remarques générales

1. Quelles ressources spécifiques avez-vous trouvées sur le web qui vous ont aidé à recommander des mesures d'atténuation ?

J'ai surtout utilisé le site de l'ANSSI (l'agence nationale de sécurité) et celui de Cybermalveillance.gouv.fr parce qu'ils donnent des fiches pratiques pour chaque type d'attaque. J'ai aussi regardé les doc technique de Cisco vu que c'est le cours.

2. Recherchez sur le web les 5 principales menaces de cybersécurité auxquelles sont confrontées les petites et moyennes entreprises (PME) et les grandes entreprises (PME). Répertoriez les menaces dans le tableau et suggérez des techniques d'atténuation pour les contrer. Les réponses varient, les sites web répertoriant les différentes menaces. Ce n'est pas un problème. Assurez-vous simplement que les informations sont récentes et recherchez brièvement leur source pour vérifier leur qualité.
 - a. Où avez-vous trouvé vos informations ? Copiez et collez l'URL ci-dessous.

<https://www.cert.ssi.gouv.fr/cti/CERTFR-2024-CTI-001/>

- b. Quel est le nom de l'entreprise qui a fourni les informations ?

ANSSI (Agence nationale de la sécurité des systèmes d'information)

- c. Quelle est la nature de l'entreprise ?

C'est une agence gouvernementale française rattaché au Secrétariat général de la défense et de la sécurité nationale (SGDSN).

d. Complétez le tableau ci-dessous.

Menace	Recommandation d'atténuation
Ransomware (Rançongiciel)	Faire des sauvegardes régulières hors ligne et utiliser un bon antivirus
Phishing (Hameçonnage)	Former les employés à ne pas cliquer sur les liens louche dans les mails.
Mots de passe faibles	Mettre en place l'authentification à deux facteurs (MFA/2FA).
Attaques par déni de service (DDoS)	Utiliser des services de protection contre les DDoS (comme Cloudflare) pour filtrer le trafic.
Intrusion via un tiers (Supply Chain)	Limiter les accès des fournisseurs au strict nécessaire (principe de moindre privilège).

VALIDATION :